Gestión en Soporte y Seguridad en Hardware y Software

Docente: Cristian Navarrete O.

GSSHS Controles de Acceso

La Autorización del protocolo Los Servicios de seguridad basados en AAA

La autorización, dentro del marco AAA (Autenticación, Autorización y Contabilidad), es el proceso que define los permisos y privilegios de un usuario después de que su identidad ha sido verificada. Determina a qué recursos, servicios o datos puede acceder, utilizando reglas de políticas de seguridad y el rol asignado a cada usuario. La autorización funciona de manera jerárquica, por ejemplo, un administrador puede tener acceso total, mientras que un usuario común tendrá acceso a recursos específicos relacionados con su trabajo.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

La Autorización del protocolo Los Servicios de seguridad basados en AAA

Cómo funciona la autorización en AAA

Proceso post-autenticación: La autorización ocurre después de la autenticación, que es el primer paso donde se verifica la identidad del usuario (por ejemplo, con una contraseña).

Asignación de privilegios: Una vez autenticado, el servidor AAA comprueba la base de datos para determinar qué permisos tiene el usuario para realizar acciones (como ver, editar o administrar) en la red y en los recursos específicos.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

La Autorización del protocolo Los Servicios de seguridad basados en AAA

Cómo funciona la autorización en AAA

Aplicación de políticas: Las políticas de seguridad de la organización se aplican para conceder los privilegios correspondientes. Por ejemplo, un usuario podría tener acceso a una carpeta específica de la red, pero no a otras.

Reducción de riesgos: Al limitar el acceso solo a lo que un usuario necesita para realizar sus tareas, la autorización ayuda a reducir el riesgo de uso indebido de datos sensibles.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

La Autorización del protocolo Los Servicios de seguridad basados en AAA

Ejemplo de Autorización

Si un usuario intenta iniciar sesión en un sistema, primero se autentica con sus credenciales. Una vez que se valida su identidad, la etapa de autorización determina si ese usuario tiene permisos para acceder a, por ejemplo:

- Una carpeta de proyectos.
- Una base de datos.
- La configuración de la red.

La autorización solo permitirá el acceso a aquellos recursos para los que el usuario ha sido explícitamente autorizado

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Normativas IEEE y RCF 2138

Las normativas **IEEE** son estándares técnicos establecidos por el Instituto de Ingenieros Eléctricos y Electrónicos para diversas áreas como la electrónica, informática y telecomunicaciones. Las siglas **RFC** (Request for Comments) se refieren a documentos que establecen estándares y mejores prácticas para Internet, y son mantenidos por el IETF. La referencia a **RCF 2138** es incorrecta; lo más probable es que se refiera a la normativa IEEE 830-1998 para especificaciones de requisitos de software.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Normativas IEEE y RCF 2138

Normativa IEEE

¿Qué son? Conjuntos de estándares creados por el Instituto de Ingenieros Eléctricos y Electrónicos para unificar y guiar la forma de presentar trabajos, desarrollar tecnologías y establecer especificaciones técnicas.

Ejemplos:

- IEEE 802.3: Define las especificaciones de la capa física y de control de acceso al medio para Ethernet.
- IEEE 2883: Proporciona métodos para la sanitización de almacenamiento de datos (Clear, Purge y Destruct).
- IEEE 830: Fue un estándar para especificaciones de requisitos de software que definió cómo debe ser un documento SRS (Software Requirements Specification).

AIEP DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Normativas IEEE y RCF 2138

RFC (Request for Comments)

¿Qué son? Son documentos publicados por el Internet Engineering Task Force (IETF) que describen estándares de Internet, metodologías y protocolos..

Subseries: Se dividen en dos subseries principales:

STD (Standard): Documentos que contienen los estándares de Internet.

BCP (Best Current Practice): Documentos que describen las mejores prácticas actuales para Internet.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Normativas IEEE y RCF 2138

RFC (Request for Comments)

Referencia a RCF: La referencia a RCF 2138 es probablemente un error. La sigla correcta sería RFC, y el número 2138 corresponde a un documento específico del IETF que trata sobre protocolos de red. El error podría estar en la "C" de "RCF" en lugar de "RFC", o en la confusión con la normativa de software IEEE 830.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Normativas IEEE y RCF 2138

¿Cuál es la diferencia?

IEEE: Es una organización profesional que crea estándares en una amplia gama de campos de la ingeniería eléctrica, electrónica, informática y más.

RFC: Es un protocolo de documentación para los estándares de Internet, administrado por el IETF.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones finales de seguridad

Las consideraciones finales de ciberseguridad incluyen la implementación de una defensa en profundidad con un enfoque de "confianza cero" (Zero Trust), el uso de la autenticación multifactor (MFA) y la gestión sólida de identidades y accesos (IAM), el cifrado de datos, el monitoreo constante de la red y la respuesta proactiva a incidentes. La resiliencia, la gestión de riesgos, el cumplimiento de normativas y la capacitación continua del personal son también fundamentales para la protección a largo plazo.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones finales de seguridad

Principios y Estrategias

Defensa en profundidad y confianza cero: Adopte un enfoque de seguridad multicapa que asuma que cualquier usuario o dispositivo podría estar comprometido, incluso dentro de la red. Un modelo de confianza cero exige autenticación antes de conceder el acceso.

Gestión de identidades y accesos (IAM): Implemente soluciones de IAM que definan roles y privilegios de acceso, requieran autenticación multifactor y proporcionen visibilidad de actividades sospechosas.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones finales de seguridad

Principios y Estrategias

Cifrado de datos: Asegúrese de que los datos estén cifrados tanto en tránsito como en reposo, incluyendo el cifrado completo del disco duro en puntos finales como portátiles para proteger la información en caso de pérdida o robo.

Monitoreo y respuesta: Establezca sistemas para monitorear continuamente la actividad de la red y responda rápidamente a los incidentes. Esto incluye el establecimiento de un Equipo de Respuesta a Incidentes de Seguridad Informática (CSIRT) para gestionar y mitigar ataques.

Resiliencia: Desarrolle la capacidad de la organización para recuperarse rápidamente de un incidente de ciberseguridad y mantener operaciones críticas.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones finales de seguridad

Prácticas y procesos

Contraseñas robustas: Utilice contraseñas complejas (combinando mayúsculas, minúsculas, números y símbolos), cámbielas regularmente y no las reutilice en diferentes servicios.

Gestión de aplicaciones y extensiones: Tenga cuidado con los permisos que otorga a extensiones de navegador y aplicaciones, especialmente las que se conectan a través de perfiles de redes sociales, ya que pueden facilitar el acceso a sus datos.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones finales de seguridad

Prácticas y procesos

Protección de puntos finales: Implemente herramientas y procesos de seguridad avanzados para proteger todos los dispositivos, incluyendo servidores, ordenadores y dispositivos móviles.

Cumplimiento de normativas: Asegúrese de cumplir con la legislación y los requisitos específicos de su sector, como los plazos para notificar incidentes establecidos en leyes como la Ley de Ciberseguridad de Chile.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones finales de seguridad

Consideraciones Adicionales

Capacitación continua: Eduque constantemente al personal sobre las mejores prácticas de ciberseguridad para minimizar el riesgo de errores humanos.

Conciencia de los riesgos: Comunique los riesgos asociados a la ciberseguridad, como las pérdidas financieras, las violaciones de datos y el daño a la reputación, y cómo la protección adecuada puede mitigar estos impactos.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones de seguridad de capa 2

Consideraciones Adicionales

Las consideraciones de seguridad de capa 2 (enlace de datos) se centran en proteger la red local mediante la implementación de protocolos como DHCP Snooping (es una función de seguridad de red que crea una base de datos de enlaces de direcciones IP-MAC válidos al monitorear el tráfico entre clientes y un servidor DHCP confiable), Port Security y MACsec para prevenir ataques como el suplantación de MAC, el envenenamiento ARP y ataques de suplantación de DHCP. Las estrategias clave incluyen la segmentación de la red con VLANs, la configuración de seguridad en los puertos de los switches para controlar el acceso de dispositivos, y el uso de encriptación para proteger la comunicación.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones de seguridad de capa 2

Amenazas comunes en la capa 2

Suplantación de MAC (MAC Spoofing): Un atacante falsifica la dirección MAC de un dispositivo para robar su identidad de red.

Envenenamiento ARP (ARP Poisoning): Un atacante interrumpe la comunicación redirigiendo el tráfico al falsificar la tabla ARP, que asocia direcciones IP con direcciones MAC.

Suplantación de DHCP (DHCP Spoofing): Se establece un servidor DHCP falso para interceptar las solicitudes de los clientes y robar información o distribuir configuraciones maliciosas.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones de seguridad de capa 2

Medidas de Seguridad y Protocolos

DHCP Snooping: Filtra el tráfico DHCP no autorizado para prevenir la suplantación de DHCP y la distribución fraudulenta de direcciones IP.

Port Security: Limita el acceso a un puerto del switch solo a los dispositivos autorizados, basándose en sus direcciones MAC, según el estándar 802.1x.

MACsec (IEEE 802.1AE): Proporciona cifrado y autenticación en la capa de enlace de datos para prevenir la interceptación (sniffing) y asegurar la integridad y el origen de los datos.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones de seguridad de capa 2

Medidas de Seguridad y Protocolos

VLANS: Segmentan lógicamente la red para aislar el tráfico. Es importante deshabilitar puertos no utilizados y asignarlos a una VLAN deshabilitada para prevenir el acceso no autorizado.

STP (Spanning Tree Protocol) y SPB: Previenen bucles de red y ataques de inundación de tramas al asegurar que solo haya un camino activo entre dispositivos.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

GSSHS Controles de Acceso

Consideraciones de seguridad de capa 2

Consideraciones Adicionales

La seguridad de capa 2 es solo una parte de una defensa en capas. Debe complementarse con medidas de seguridad en otras capas, como firewalls (capa 3/4) y cifrado de extremo a extremo.

La seguridad de los switches de capa 2 a menudo se puede mejorar implementando protocolos de seguridad y configuraciones de hardening.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO